



Avenue du Ciseau, 15 – 1348 Louvain-la-Neuve

Analyse et choix technologiques

Travail de Fin d'Études

Déploiement d'une solution IDS/IPS et SIEM augmentée par l'intelligence artificielle en environnement virtualisé

Étudiant :	Arno Stärkel
Rapporteur :	Laurent Schalkwijk
Clients :	Sophie Veron & Marco Citta (Eurostar)
Année académique :	2025 – 2026
Session :	Seconde session
Dépôt rapport :	17 août 2026

Bachelier en Technologie de l'Informatique

Table des matières

1	Contexte et problématique	4
1.1	Contexte général	4
1.2	Problématique	4
1.3	Enjeux et objectifs	5
2	Présentation des intervenants	5
2.1	Les clients	5
2.2	Synthèse des intervenants	6
3	Contraintes	6
3.1	Contraintes matérielles	6
3.2	Contraintes temporelles	6
3.3	Contraintes techniques	6
3.4	Contraintes réglementaires	7
4	Fondamentaux théoriques	7
5	Analyse comparative et choix technologiques	8
5.1	Rappel des besoins fonctionnels et non fonctionnels	8
5.2	Méthodologie de comparaison	10
5.3	IDS/IPS — Suricata vs Snort vs Zeek	10
5.4	SIEM — Wazuh vs Elastic SIEM vs Splunk vs QRadar	11
5.5	Simulation réseau — GNS3 vs EVE-NG vs Cisco CML	12
5.6	Conteneurisation — Docker vs Podman vs LXC/LXD	13
5.7	Agent HIDS — Wazuh Agent vs OSSEC vs Auditd vs Samhain	14
5.8	Déploiement multi-sites — Ansible vs Puppet vs Chef vs Terraform	15
5.9	LLM local — Ollama vs LM Studio vs llama.cpp	15
5.10	Framework agent IA — LangChain vs LlamaIndex vs AutoGen vs CrewAI	16
5.11	Synthèse de la stack technique retenue	17
6	Architecture du laboratoire	18
6.1	Décisions architecturales	18
6.2	Segmentation réseau	18

6.3	Plan d’adressage IP	18
6.4	Flux de données	18
6.5	Politique de filtrage pfSense	21
7	Scénarios d’attaque	21
7.1	Cadre méthodologique — MITRE ATT&CK	21
7.2	Sélection et définition des scénarios	21
7.3	Scénario A — Reconnaissance réseau (Nmap) Complexité : ★	22
7.4	Scénario B — Force brute SSH (Hydra) Complexité : ★★	22
7.5	Scénario C — Injection SQL (sqlmap) Complexité : ★★	22
7.6	Scénario D — Exploitation Metasploit (vsftpd 2.3.4 [16]) Complexité : ★★★	23
7.7	Scénarios bonus — Si le temps le permet	23
8	Stratégie de validation	24
8.1	Trois niveaux complémentaires	24
8.2	Critères d’acceptation par fonctionnalité	24
8.3	Critères d’acceptation par scénario	26
8.4	Validation du composant IA	26
9	Analyse de sécurité et conformité RGPD	26
9.1	Dimension réflexive	26
9.2	Biens à protéger	27
9.3	Matrice des risques	27
9.4	Contre-mesures	27
9.5	Risques résiduels	27
9.6	Conformité RGPD	28
10	Planning de réalisation	28
10.1	Contraintes temporelles	28
10.2	Planning détaillé	28
10.3	Jalons go/no-go et itérations	29
11	Conclusion	29
	Bibliographie	30

1. Contexte et problématique

1.1. Contexte général

La cybersécurité est aujourd’hui un enjeu stratégique majeur. Selon l’ENISA [5], le nombre d’incidents significatifs en Europe est en hausse constante, porté par la multiplication des rançongiciels, des exfiltrations de données et des menaces persistantes avancées (APT¹).

Eurostar, entreprise ferroviaire trans-Manche opérant sur plusieurs sites géographiques, gère une infrastructure complexe hébergeant des données sensibles soumises au RGPD. Face à la sophistication croissante des attaques, les pare-feux et antivirus seuls sont insuffisants : les équipes de sécurité ont besoin de **visibilité en temps réel** et de la capacité à **détecter, corréler et répondre** rapidement aux incidents.

1.2. Problématique

La problématique centrale de ce travail peut être formulée comme suit :

Problématique

Comment concevoir et déployer une solution intégrée de détection et de prévention des intrusions (IDS/IPS) couplée à un système de gestion des informations et des événements de sécurité (SIEM), répondant aux exigences opérationnelles d’une grande entreprise telle qu’Eurostar — telles que formalisées dans le cahier des charges avec Sophie Veron et validées à l’issue de chaque itération — tout en étant réalisable dans le cadre d’un environnement de laboratoire ?

Cette problématique implique plusieurs dimensions complémentaires :

- **Technique** : sélectionner, configurer et intégrer des outils de détection réseau (tels que Suricata ou Snort) avec une plateforme SIEM (telle que Wazuh ou Elastic SIEM), de manière à former une chaîne de traitement unifiée — de la capture du trafic jusqu’à l’alerte SOC — et vérifiée sur les quatre scénarios d’attaque retenus ;
- **Opérationnelle** : s’assurer que la solution produit des alertes exploitables par une équipe SOC², avec une gestion différenciée des niveaux de criticité ;
- **Analytique** : démontrer la capacité de la solution à reconstituer une chaîne d’attaque (*kill chain* [9]) à partir d’événements corrélés, sur la base de scénarios d’attaque représentatifs ;
- **Intelligence artificielle** : intégrer des mécanismes d’apprentissage automatique capables de réduire les faux positifs et les faux négatifs, de prioriser les alertes et de contribuer à la reconstruction automatique de la chaîne d’attaque — constituant

1. Advanced Persistent Threat : attaque prolongée et ciblée, orchestrée par des acteurs disposant de ressources importantes.

2. Security Operations Center : centre opérationnel de sécurité chargé de surveiller, détecter et répondre aux incidents de cybersécurité.

ainsi la **plus-value centrale** de ce travail par rapport aux solutions IDS/IPS et SIEM conventionnelles ;

- **Organisationnelle** : proposer une architecture scalable, maintenable et compatible avec un environnement hybride (cloud et infrastructure interne).

1.3. Enjeux et objectifs

Ce travail de fin d'études poursuit les objectifs suivants :

1. Étudier et comparer les solutions existantes dans le domaine des IDS/IPS et des SIEM afin d'identifier les outils les mieux adaptés aux contraintes du projet ;
2. Concevoir une architecture de détection et de supervision de la sécurité répondant aux besoins exprimés par le client ;
3. Déployer un environnement de laboratoire fonctionnel permettant de simuler et de valider quatre scénarios d'attaque représentatifs, dans le respect des contraintes matérielles et temporelles détaillées en section 3 ;
4. **Intégrer des mécanismes d'intelligence artificielle** au sein de la solution, constituant la plus-value distinctive de ce TFE : réduction des faux positifs par détection d'anomalies, priorisation automatique des alertes et reconstruction assistée de la chaîne d'attaque ;
5. Produire une documentation technique et opérationnelle utilisable par une équipe SOC.

2. Présentation des intervenants

2.1. Les clients

Sophie Veron, Senior Information Security Expert chez Eurostar, est la cliente principale de ce TFE. Elle a contribué à la définition des besoins lors de plusieurs échanges directs avec l'étudiant : formalisation des onze besoins fonctionnels (BF-01 à BF-11) et des dix besoins non fonctionnels (BNF-01 à BNF-10), validation du périmètre de détection concentré sur quatre scénarios d'attaque représentatifs plutôt que sur une multiplication de cas partiellement traités, et sélection des types de menaces prioritaires pour Eurostar (balayage réseau, force brute SSH, injection SQL, exploitation d'une vulnérabilité critique).

Marco Citta, IT Program Director chez Eurostar, est le client secondaire. C'est à son initiative que le contact avec Sophie Veron a été établi. Il intervient en complément de Sophie Veron et apporte un éclairage stratégique sur les enjeux IT d'Eurostar.

2.2. Synthèse des intervenants

Intervenant	Rôle	Responsabilités dans le projet
Arno Stärkel	Étudiant	Conception, déploiement, documentation et rédaction du TFE
Laurent Schalkwijk	Rapporteur	Suivi académique
Sophie Veron	Cliente principale	Définition des besoins, sélection des scénarios
Marco Citta	Client secondaire	Point de contact de substitution, vision stratégique IT

3. Contraintes

3.1. Contraintes matérielles

Le déploiement sera réalisé dans un environnement de laboratoire local, sur une machine personnelle (Intel Core i5-12450H, 16 Go RAM, 512 Go SSD, Ubuntu 24.04 LTS). Cette contrainte implique que certaines exigences — notamment la capacité à absorber un trafic de 10 Gbps (BNF-01) ou le déploiement effectif sur plusieurs sites géographiques (BF-10) — ne pourront pas être validées dans leur pleine dimension en environnement de laboratoire. Ces points feront l'objet d'une justification théorique et architecturale dans le rapport final.

3.2. Contraintes temporelles

Le présent travail est réalisé dans le cadre de la seconde session de l'année académique 2025–2026. Le rapport final doit être déposé au plus tard le **17 août 2026**, et la défense orale aura lieu en **septembre 2026**. Ce calendrier implique une organisation rigoureuse et une priorisation claire des tâches, notamment en ce qui concerne le déploiement du laboratoire et la validation des scénarios d'attaque.

Le travail est mené en autonomie complète durant cette période, sans encadrement régulier du rapporteur prévu par le règlement de seconde session.

3.3. Contraintes techniques

L'environnement simulé en laboratoire ne peut pas reproduire fidèlement la complexité d'une infrastructure d'entreprise réelle telle que celle d'Eurostar. Le trafic réseau sera généré artificiellement à des fins de test, et les données manipulées seront exclusivement fictives ou issues d'outils de simulation. En aucun cas des données réelles provenant du système d'information d'Eurostar ne seront utilisées dans le cadre de ce projet.

Par ailleurs, la contrainte de rétention des journaux sur un an (BNF-10) sera couverte sur le plan architectural — en documentant la solution technique qui permettrait de

l'implémenter — sans pouvoir être vérifiée empiriquement dans le laboratoire.

3.4. Contraintes réglementaires

Le projet doit tenir compte du Règlement Général sur la Protection des Données (RGPD), en veillant à ce qu'aucune donnée à caractère personnel ne soit collectée, stockée ou traitée dans le cadre des expérimentations réalisées en laboratoire. Les scénarios d'attaque simulés utiliseront exclusivement des données fictives : adresses IP, noms d'hôtes et identifiants inventés de toutes pièces, ne correspondant à aucune personne ou infrastructure réelle. Ce choix est dicté par le RGPD [23] : les adresses IP étant qualifiées de données à caractère personnel par la CJUE [2], leur traitement en laboratoire exigerait une base légale et des mesures de protection disproportionnées au regard des objectifs pédagogiques du projet. Les données fictives sont générées directement par les outils d'attaque (Nmap, Hydra, sqlmap, Metasploit) opérant sur des machines virtuelles dédiées.

4. Fondamentaux théoriques

Un **IDS** (Intrusion Detection System) surveille le trafic réseau ou l'activité d'un système pour détecter des comportements suspects et alerter les équipes de sécurité — il **observe et signale**. Un **IPS** (Intrusion Prevention System) y ajoute une dimension active : il peut bloquer automatiquement les flux malveillants, rejeter des paquets ou réinitialiser des connexions. Les outils modernes opèrent dans l'un ou l'autre mode selon leur configuration.

On distingue deux familles : le **NIDS** (Network-based IDS), qui inspecte le trafic réseau en transit, et le **HIDS** (Host-based IDS), déployé sur une machine pour surveiller ses activités locales. Le NIDS ne peut pas inspecter le trafic chiffré (TLS/SSL) — d'où l'exigence BF-01 de compléter la couverture par des agents HIDS sur les serveurs exposant des services chiffrés.

La détection repose sur deux méthodes complémentaires. La **détection par signatures** compare le trafic à des empreintes d'attaques connues : fiable et rapide, mais aveugle aux menaces inédites. La **détection par anomalies** établit une baseline du comportement normal et signale tout écart significatif : capable de détecter des attaques inconnues, mais génératrice de faux positifs. La détection par signatures, à l'inverse, expose à des faux négatifs (attaques inédites non détectées faute de signature) [6]. C'est précisément cette tension qui justifie l'intégration de l'IA (BF-11) pour modéliser la baseline, réduire les faux positifs et limiter les faux négatifs. En mode **inline**, l'IPS est inséré dans le flux réel et peut bloquer en temps réel — exigence de BF-03. Exemple de règle de détection par signature :

```
1 alert tcp any any -> $HOME_NET 22 (  
2   msg:"ET SCAN Potential SSH Scan";  
3   flags:S;  
4   threshold: type both, track by_src, count 5, seconds 60;  
5   classtype:attempted-recon; sid:2001219; rev:20;  
6 )
```

Listing 1 – Règle Suricata — Détection scan SSH

Un **SIEM** (Security Information and Event Management) est une plateforme centralisée qui collecte, normalise, corrèle et analyse les événements de sécurité de l'ensemble du système d'information. Ses cinq fonctions essentielles sont la **collecte** (via agents ou Syslog), la **normalisation** (conversion en format unifié), la **corrélation** (relier des événements isolés pour révéler une attaque — cœur de BF-05), le **stockage** long terme (BNF-10 exige un an minimum) et la **visualisation** via tableaux de bord SOC (BF-07).

L'IDS/IPS et le SIEM sont **complémentaires, non redondants**. Sans le SIEM, chaque alerte de l'IDS est un événement isolé ; avec le SIEM, ces événements deviennent une narration d'attaque. Le composant IA (BF-11) soutient les trois niveaux du SOC : réduction des faux positifs et des faux négatifs pour le Tier 1 (surveillance), reconstruction de la kill chain pour le Tier 2 (investigation), suggestions de réponse pour le Tier 3 (remédiation).

Exemple de normalisation d'un log web par le SIEM :

```

1 # Log brut
2 192.168.1.50 - [21/May/2026] "GET /admin/config.php" 404 "sqlmap
   /1.7.8"
3 # Evenement normalise
4 { "timestamp":"2026-05-21T14:32:01Z", "source_ip":"192.168.1.50",
5   "url":"/admin/config.php", "http_status":404,
6   "user_agent":"sqlmap/1.7.8",
7   "rule":{"level":10,"description":"SQL injection attempt detected"} }
```

Listing 2 – Normalisation d'un log Apache par Wazuh

5. Analyse comparative et choix technologiques

5.1. Rappel des besoins fonctionnels et non fonctionnels

Les choix technologiques présentés dans cette section sont directement conditionnés par les besoins fonctionnels et non fonctionnels formalisés avec Sophie Veron (Eurostar) dans le cahier des charges. Ils sont rappelés ici dans leur intégralité afin que le lecteur puisse suivre la logique de chaque décision sans avoir à se référer au document précédent.

Besoins fonctionnels

- BF-01 Collecte centralisée des événements de sécurité.** La solution collecte les événements de l'ensemble du SI : réseau, serveurs, postes de travail. Pour les flux chiffrés (TLS/SSL) non inspectables par un capteur réseau passif, des agents HIDS sont déployés directement sur les machines concernées.
- BF-02 Détection des menaces.** La solution détecte les comportements suspects et les attaques connues ou émergentes. La détection est concentrée sur quatre scénarios représentatifs, validés avec le client, en privilégiant la profondeur de couverture plutôt que la quantité.
- BF-03 Prévention active des attaques.** En mode IPS, la solution bloque automatiquement les flux malveillants sans intervention humaine, en temps réel.

- BF-04** **Gestion différenciée des alertes par niveau de criticité.** La solution distingue au moins quatre niveaux : informatif, suspect, menace confirmée, incident critique. Les menaces avérées déclenchent un blocage ou une escalade automatique.
- BF-05** **Corrélation des événements et reconstruction de la chaîne d'attaque.** La solution corrèle les événements réseau avec les journaux système pour reconstituer une kill chain complète, en s'appuyant sur le référentiel MITRE ATT&CK.
- BF-06** **Génération d'alertes exploitables par une équipe SOC.** Chaque alerte contient au minimum : règle déclenchée, horodatage, adresses IP source et destination, ports, protocole et niveau de sévérité.
- BF-07** **Intégration au SIEM et tableau de bord opérationnel.** Le SIEM produit un tableau de bord présentant une vue temps réel et une vue historisée (24 h et 4 semaines), personnalisable par rôle.
- BF-08** **Aide à la réponse à incident.** La solution offre des mécanismes d'escalade automatisés (notifications, tickets) et permet l'acquittement automatique des alertes bénignes connues.
- BF-09** **Administration des règles de détection.** Les signatures et politiques de détection sont administrables (création, modification, désactivation, mise à jour automatique depuis des sources tierces). Toute modification est tracée et réversible.
- BF-10** **Déploiement multi-sites.** L'architecture est conçue pour être déployée de manière cohérente sur plusieurs sites géographiques sans refonte. Dans le cadre de ce laboratoire, ce besoin fera l'objet d'une justification théorique et d'une démonstration partielle via Ansible.
- BF-11** **Assistance par intelligence artificielle.** L'intégration IA constitue la plus-value centrale de ce TFE : réduction des faux positifs et des faux négatifs, priorisation automatique des alertes, et reconstruction assistée de la chaîne d'attaque en langage naturel.

Besoins non fonctionnels

Code	Critère	Description
BNF-01	Performance	Ne pas dégrader les performances réseau ; absorber un trafic atteignant 10 Gbps.
BNF-02	Disponibilité	Fonctionner en permanence ; une interruption ne doit pas bloquer la détection.
BNF-03	Fiabilité	Produire des alertes cohérentes en limitant doublons et pertes d'événements.
BNF-04	Faux positifs	Limiter les alertes injustifiées pour préserver la confiance des analystes.
BNF-05	Scalabilité	Intégrer de nouveaux sites et sources de logs sans refonte de l'architecture.
BNF-06	Compatibilité	Fonctionner en environnement hybride (cloud, on-premise, outils existants).
BNF-07	Maintenabilité	Être administrable sans complexité excessive par une équipe interne.
BNF-08	Sécurité	Restreindre l'accès à l'interface et aux paramètres aux personnes autorisées.
BNF-09	Traçabilité	Journaliser toutes les actions : alertes, configurations, blocages, interventions.
BNF-10	Conservation	Conserver les journaux de sécurité avec une rétention minimale d'un an.

5.2. Méthodologie de comparaison

Pour chaque composant de la stack technique, les alternatives ont été évaluées selon une grille de critères dérivée directement des besoins ci-dessus et des contraintes matérielles de la machine de développement (16 Go RAM, Ubuntu 24.04 LTS). Chaque tableau fait apparaître une colonne **Lien CDC** qui trace explicitement la relation entre le critère évalué et le besoin correspondant. La notation utilisée est la suivante : ✓ = oui, ○ = partiel, × = non.

5.3. IDS/IPS — Suricata vs Snort vs Zeek

Présentation des solutions. **Snort** est l'IDS/IPS historique, créé en 1998 et aujourd'hui maintenu par Cisco. C'est la référence académique mondiale dont le langage de règles est devenu un standard de facto. **Suricata** est son successeur spirituel, développé depuis 2009 par l'OISF, conçu dès le départ pour exploiter les architectures multi-cœurs modernes. **Zeek** (anciennement Bro) est fondamentalement différent : ce n'est pas un IDS au sens classique mais un générateur de logs réseau structurés très riches, sans capacité de blocage natif.

Critère	Lien CDC	Snort	Suricata	Zeek
Détection par signatures	BF-02	✓	✓	○
Détection par anomalies	BF-02, BF-11	○	○ / ✓	✓
Mode IPS — blocage actif	BF-03	✓	✓	×
Multi-thread natif	BNF-01	○	✓	✓
Format de logs structurés pour IA	BF-11	×	✓	✓
Intégration SIEM native	BF-07	○	✓	○
Support TLS fingerprinting	BF-01	×	✓	✓
Compatibilité Docker/GNS3	Lab	✓	✓	✓
Courbe d'apprentissage	Contexte	Facile	Facile	Difficile
Licence	Budget	GPLv2	GPLv2	BSD
Documentation francophone	TFE	✓	✓	○

Analyse. Snort 2, la version la plus documentée, est mono-thread et n'exploiterait qu'un seul cœur sur les 12 disponibles. Snort 3 corrige cela mais sa documentation est moins abondante. Zeek est fascinant intellectuellement mais son absence de capacité de blocage actif le rend incompatible avec BF-03. Il est à mentionner comme outil complémentaire utilisé dans les grands SOC, mais à exclure de cette implémentation. Suricata répond à l'ensemble des exigences : architecture multi-thread native, format EVE JSON structuré indispensable à l'intégration IA, mode IPS inline, et support du TLS fingerprinting pour les flux chiffrés.

Architecture multi-thread native, format EVE JSON facilitant l'intégration SIEM et l'agent IA, mode IPS inline via NFQueue [19], [20], support TLS fingerprinting. Justifié par BF-02, BF-03, BF-11 et BNF-01.

5.4. SIEM — Wazuh vs Elastic SIEM vs Splunk vs QRadar

Présentation des solutions. **Wazuh** est une plateforme open source de sécurité unifiée, née en 2015 comme fork d'OSSEC [29], intégrant nativement SIEM, HIDS, réponse active et MITRE ATT&CK [15]. **Elastic SIEM** est le module de sécurité de la stack ELK, très puissant et flexible, très utilisé en entreprise. **Splunk** est la référence commerciale du marché, réputé pour sa puissance d'analyse. **QRadar** est le SIEM d'IBM, très présent dans les secteurs critiques (finance, énergie, transports).

Critère	Lien	Wazuh	Elastic	Splunk	QRadar
Agent HIDS intégré	BF-01	✓	×	×	×
MITRE ATT&CK natif	BF-05	✓	✓	✓	✓
Corrélation événements	BF-05	✓	✓	✓	✓
Réponse active	BF-08	✓	○	✓	✓
Dashboard opérationnel	BF-07	✓	✓	✓	✓
Intégration ML/IA	BF-11	○	✓	✓	✓
Déploiement Docker officiel	Lab	✓	○	×	×
RAM requise	Machine	≈5 Go	8–12 Go	Elevée	Elevée
Coût	Budget	Gratuit	Limité	Payant	Payant

Analyse. Splunk et QRadar sont exclus pour des raisons de licence et de ressources matérielles incompatibles avec le laboratoire. Elastic SIEM est une alternative technique sérieuse, mais sa stack complète (Elasticsearch + Logstash + Kibana + agents) consomme entre 8 et 12 Go de RAM en configuration lab correcte — incompatible avec la machine disponible une fois les autres composants lancés. Ses fonctionnalités ML avancées nécessitent par ailleurs une licence Platinum payante. Wazuh répond à l'ensemble des contraintes : agent HIDS intégré (BF-01), déploiement Docker en trois commandes, MITRE ATT&CK natif dans chaque alerte, et réponse active (BF-08). Son absence de ML natif avancé est en réalité un **avantage pour ce TFE** : elle justifie et valorise la plus-value IA (BF-11) plutôt que de la couvrir par une fonctionnalité existante.

Agent HIDS intégré (BF-01), déploiement Docker officiel, MITRE ATT&CK natif dans chaque alerte, réponse active (BF-08), compatible 16 Go RAM. L'absence de ML natif est délibérément compensée par le composant IA (BF-11), plus-value centrale du TFE.

5.5. Simulation réseau — GNS3 vs EVE-NG vs Cisco CML

Présentation des solutions. **GNS3** est un émulateur réseau open source très utilisé dans les labs de cybersécurité et les certifications réseau. **EVE-NG** est son concurrent direct, très populaire en environnement professionnel avec une interface entièrement web. **Cisco CML** (Modeling Lab) est la plateforme de simulation réseau professionnelle de Cisco, successeur de VIRL, orientée entreprise et certifications avancées.

Critère	Lien	GNS3	EVE-NG	Cisco CML
Support Docker natif	Stack	✓	○	×
Support Linux (Kali/Ubuntu)	Lab	✓	✓	✓
Topologie visuelle	Rapport	✓	✓	✓
Installation Ubuntu native	Contrainte	✓	○	×
Consommation RAM	Machine	✓	○	○
Intégration scénarios cyber	Lab	✓	✓	✓
Licence	Budget	Gratuit	Grat./Pro	Payant

Analyse. Cisco CML est une plateforme professionnelle orientée certifications Cisco ; elle ne supporte pas Docker et son modèle de licence payant la rend incompatible avec les contraintes budgétaires et matérielles du laboratoire. EVE-NG est une alternative professionnelle sérieuse, mais le support Docker est réservé à la version Pro payante, et son installation sur Ubuntu nécessite une VM intermédiaire consommant plusieurs Go de RAM supplémentaires. GNS3 supporte Docker nativement et gratuitement, s’installe directement sur Ubuntu 24.04, et permet de glisser des conteneurs (attaquant, capteur IDS, cibles) directement dans la topologie visuelle.

Support Docker natif et gratuit, compatible Ubuntu 24.04 sans VM intermédiaire, communauté cybersécurité abondante, topologie exportable pour le rapport.

5.6. Conteneurisation — Docker vs Podman vs LXC/LXD

Présentation des solutions. **Docker** est la plateforme de conteneurisation la plus utilisée au monde, reposant sur un daemon central. **Podman** est l’alternative Red Hat, daemonless et rootless, techniquement plus sécurisée. **LXC/LXD** est une conteneurisation plus proche de la virtualisation légère, isolant un système Linux complet.

Critère	Lien	Docker	Podman	LXC/LXD
Support natif GNS3	Stack	✓	×	×
Déploiement SIEM officiel	Stack	✓	○	×
Docker Compose	Simplicité	✓	○	×
Architecture sécurisée	Sécurité	○	✓	✓
Consommation RAM	Machine	✓	✓	○

Analyse. LXC/LXD est exclu pour l’absence de support officiel des outils retenus. Podman est techniquement supérieur (architecture daemonless, rootless natif) mais n’est pas supporté par GNS3 et introduirait une complexité non justifiée. Docker est la seule solution compatible simultanément avec GNS3 et avec le déploiement officiel du SIEM via Docker Compose.

Seule solution compatible simultanément avec GNS3 (nœuds réseau) et le déploiement officiel du SIEM via Docker Compose.

Considération de sécurité — Docker

Docker présente une surface d’attaque plus large que ses alternatives en raison de son architecture centrée sur un daemon tournant avec les privilèges root (dockerd). Contrairement à Podman qui est nativement daemonless et rootless, Docker expose un risque d’escalade de privilèges en cas de compromission du daemon. Dans un environnement de production, des mesures de durcissement seraient nécessaires : utilisation du mode rootless, restriction des capacités Linux, et isolation réseau stricte des conteneurs. Ce risque est accepté dans le cadre de ce laboratoire pour deux raisons : le lab est isolé et non exposé à Internet, et les contraintes matérielles (16 Go RAM) rendent impossible le remplacement de Docker par une alternative sans sacrifier d’autres composants essentiels de la stack. Une architecture alternative basée sur un hyperviseur de type 1 tel que Proxmox VE aurait pu offrir une isolation plus forte, mais nécessite une installation bare-metal incompatible avec l’environnement de développement existant (Ubuntu 24.04 LTS) et aurait alourdi significativement la charge de configuration sans apporter de valeur ajoutée au périmètre de ce TFE.

5.7. Agent HIDS — Wazuh Agent vs OSSEC vs Auditd vs Samhain

Présentation des solutions. **Wazuh Agent** est le composant déployé sur les machines surveillées dans l’écosystème Wazuh. **OSSEC** est l’ancêtre direct de Wazuh (fork depuis 2015), encore utilisé dans certaines organisations. **Auditd** est le sous-système d’audit natif du noyau Linux, enregistrant les appels système à un niveau très bas. **Samhain** est un HIDS spécialisé dans la surveillance d’intégrité des fichiers et la détection de rootkits.

Critère	Lien	Wazuh Agent	OSSEC	Auditd	Samhain
Intégration SIEM native	Stack	✓	○	×	×
MITRE ATT&CK natif	BF-05	✓	×	×	×
Réponse active	BF-08	✓	✓	×	×
Intégrité fichiers (FIM)	BF-02	✓	✓	○	✓
Dashboard centralisé	BF-07	✓	○	×	×
Déploiement Ansible	BF-10	✓	○	✓	○
Communauté active	Support	✓	○	✓	○

Analyse. Samhain est exclu pour l’absence d’intégration avec le SIEM retenu. OSSEC, base de code commune avec Wazuh, ne supporte pas nativement MITRE ATT&CK et sa communauté est en déclin. Auditd, sous-système d’audit natif Linux, est un outil bas niveau pertinent mais ne constitue pas une solution HIDS autonome (ni dashboard, ni réponse active, ni intégration SIEM native) ; il n’est donc pas retenu dans la stack.

L’agent HIDS s’impose naturellement comme binôme du SIEM retenu : les deux forment un écosystème indissociable.

Intégration native avec le SIEM, MITRE ATT&CK dans chaque événement, réponse active sur la machine surveillée, déploiement Ansible et dashboard centralisé.

5.8. Déploiement multi-sites — Ansible vs Puppet vs Chef vs Terraform

Présentation des solutions. **Ansible** automatise la configuration de machines distantes via SSH (architecture agentless), en décrivant l’état souhaité dans des fichiers YAML appelés playbooks. **Puppet** et **Chef** reposent sur un modèle agent/serveur : un serveur central (Puppet Master ou Chef Server) gère les nœuds. **Terraform** est un outil d’Infrastructure as Code (IaC) qui *crée* l’infrastructure (VMs, réseaux cloud) plutôt qu’il ne configure les services qui y tournent.

Critère	Lien	Ansible	Puppet	Chef	Terraform
Architecture agentless	Simplicité	✓	×	×	✓
Langage YAML	Cohérence	✓	×	×	◦
Gestion configuration OS	BF-10	✓	✓	✓	×
Playbooks SIEM officiels	Stack	✓	◦	◦	×
Serveur central requis	Machine	×	✓	✓	×
Courbe d’apprentissage	Contexte	Facile	Elevée	Très élevée	Modérée
Licence	Budget	GPL	Grat./Pro	Grat./Pro	BSL

Analyse. Puppet et Chef nécessitent un serveur central dédié consommant plusieurs Go de RAM supplémentaires — incompatible avec les 16 Go disponibles. Terraform, outil de provisionnement d’infrastructure cloud, est hors périmètre : il crée des machines mais ne configure pas les services qui y tournent. En entreprise, Terraform et Ansible sont complémentaires (Terraform provisionne, Ansible configure), mais seul Ansible couvre le besoin de BF-10 dans ce projet. Son langage YAML est cohérent avec Docker Compose et le déploiement du SIEM dispose de playbooks officiels.

Agentless (SSH uniquement), YAML cohérent avec la stack, playbooks officiels disponibles. Un nouveau site se résume à une ligne dans le fichier d’inventaire.

5.9. LLM local — Ollama vs LM Studio vs llama.cpp

Présentation des solutions. **Ollama** simplifie radicalement le déploiement de LLM en local : une commande pour télécharger et lancer un modèle, avec exposition automatique d’une API REST compatible OpenAI. **LM Studio** est une application desktop avec

interface graphique pour tester des modèles interactivement, exposant également une API REST. **llama.cpp** est la technologie sous-jacente aux deux précédents : une implémentation C++ optimisée pour l'inférence CPU, sans interface.

Critère	Lien	Ollama	LM Studio	llama.cpp
API REST compatible OpenAI	Agent IA	✓	✓	○
Service système (systemd)	Automatisation	✓	×	×
Installation Ubuntu	Contrainte	✓	✓	○
Optimisation CPU	Machine	✓	✓	✓
Gestion multi-modèles	Flexibilité	✓	✓	○
Utilisable en script	Agent IA	✓	○	✓
Courbe d'apprentissage	Contexte	Très facile	Facile	Elevée

Analyse. llama.cpp est la technologie sous-jacente aux deux autres — l'utiliser directement nécessite de compiler le code source et de gérer manuellement les modèles. LM Studio est excellent pour explorer des modèles interactivement mais nécessite une application desktop permanente et ne peut pas démarrer automatiquement comme un service système. Ollama s'installe en une commande, démarre via systemd, et expose une API REST directement compatible avec LangChain sans configuration intermédiaire.

Concernant le **choix du modèle** : Llama 3.1 8B est retenu comme modèle principal pour ses capacités de raisonnement multi-étapes (≈6 Go RAM). Mistral 7B est maintenu comme alternative de secours (≈5 Go, plus rapide en inférence CPU seul).

Service systemd, API REST native, gestion simplifiée. Llama 3.1 8B pour le raisonnement multi-étapes ; Mistral 7B en secours si les performances CPU s'avèrent insuffisantes.

5.10. Framework agent IA — LangChain vs LlamaIndex vs AutoGen vs CrewAI

Présentation des solutions. **LangChain** est le framework open source de référence pour construire des applications LLM, avec des abstractions pour connecter un LLM à des outils externes. **LlamaIndex** est spécialisé dans l'indexation documentaire pour le RAG (*Retrieval-Augmented Generation*). **AutoGen** (Microsoft Research) orchestre des *conversations entre plusieurs agents IA* collaborant sur un problème. **CrewAI** (2024) simule une équipe de rôles professionnels, chaque agent ayant une mission et des outils dédiés.

Critère	Lien	Lang-Chain	Llama-Idx.	Auto-Gen	CrewAI
Intégration Ollama native	Stack	✓	✓	◦	◦
Analyse logs JSON temps réel	BF-11	✓	◦	✓	✓
Reconstruction kill chain	BF-05, BF-11	✓	◦	✓	✓
Construction progressive	MVP-It.3	✓	◦	◦	◦
Exemples cybersécurité	Contexte	✓	◦	◦	×
Maturité	Stabilité	✓	✓	◦	×
Courbe d'apprentissage	Contexte	Modérée	Modérée	Elevée	Modérée

Analyse. LlamaIndex est spécialisé dans le RAG documentaire — l’analyse de logs en temps réel n’est pas son cas d’usage principal. AutoGen est adapté aux architectures multi-agents complexes mais introduit une complexité de mise en œuvre supérieure à LangChain pour un résultat équivalent. CrewAI (2024) manque de maturité et d’exemples appliqués à la cybersécurité. LangChain dispose d’une classe `OllamaLLM` native, d’une flexibilité permettant une construction progressive alignée sur les trois itérations du projet, et d’une communauté cybersécurité très active.

Intégration Ollama native, construction progressive MVP→itération 3, nombreux exemples cybersécurité disponibles.

5.11. Synthèse de la stack technique retenue

Rôle	Outil retenu	Justification clé
Simulation réseau	GNS3	Docker natif gratuit, Ubuntu 24.04 natif
Conteneurisation	Docker	Seul compatible GNS3 + SIEM officiels
IDS/IPS	Suricata	EVE JSON, multi-thread, mode IPS in-line
SIEM central	Wazuh	HIDS intégré, MITRE ATT&CK, Docker
Agent HIDS	Wazuh Agent	Écosystème cohérent, réponse active
Déploiement	Ansible	Agentless, YAML, playbooks officiels
LLM local	Ollama + Llama 3.1 8B	Gratuit, API native LangChain
Agent IA	LangChain Python	Intégration Ollama, construction progressive
Versioning	GitHub	Consignes académiques, Kanban intégré
Rédaction	LaTeX / Overleaf	Bibliographie auto, .tex versionnable

6. Architecture du laboratoire

6.1. Décisions architecturales

Machine disponible : Intel Core i5-12450H, 16 Go RAM, 512 Go SSD, Ubuntu 24.04 LTS. Un déploiement **mono-site** a été retenu après analyse du budget mémoire — un bi-sites dépasserait les 16 Go en démonstration complète. BF-10 fera l'objet d'une justification théorique et d'une démonstration partielle via Ansible.

6.2. Segmentation réseau

- **DMZ (10.0.10.0/24)** : serveurs exposés (web, SSH, Metasploitable) avec agents Wazuh HIDS.
- **LAN (10.0.20.0/24)** : poste de travail interne.
- **Management (10.0.30.0/24)** : Wazuh Stack, Suricata, Agent IA — inaccessible depuis le WAN.

6.3. Plan d'adressage IP

Hostname	IP	Zone	Rôle	RAM
pfsense-fw	Multiple	Multi	Pare-feu et routage	512 Mo
web-eurostar	10.0.10.10	DMZ	Apache + MySQL + Wazuh Agent	256 Mo
ssh-eurostar	10.0.10.20	DMZ	OpenSSH + Wazuh Agent	256 Mo
metasploitable	10.0.10.30	DMZ	vsftpd vulnérable + Wazuh Agent*	512 Mo
workstation-it	10.0.20.50	LAN	Poste interne + Wazuh Agent	256 Mo
wazuh-stack	10.0.30.10	MGMT	Manager + Indexer + Dashboard	5 Go
suricata-sensor	10.0.30.20	MGMT	NIDS/IPS inline (NFQueue [17])	512 Mo
ai-agent	10.0.30.30	MGMT	Ollama + LangChain Python	5,5 Go
kali-attacker	192.168.1.50	WAN	Attaquant simulé	1 Go
Total estimé				≈14 Go

* L'agent Wazuh est déployé sur Metasploitable2 à titre de capteur HIDS (surveillance de l'intégrité des fichiers et des processus lors de l'exploitation), bien que cette machine soit une cible volontairement vulnérable et non une machine réellement administrée.

6.4. Flux de données

1. L'attaquant génère du trafic malveillant vers la DMZ ;

2. pfSense filtre selon le principe du moindre privilège ;
3. Suricata inspecte le trafic en mode inline (EVE JSON) ;
4. Les agents Wazuh collectent les logs système locaux ;
5. Le Wazuh Manager normalise, corrèle, mappe MITRE ATT&CK ;
6. L'agent IA reconstruit la kill chain via l'API Wazuh ;
7. Le Dashboard expose les résultats aux analystes SOC.

La figure 1 synthétise l'ensemble de ces flux et la segmentation retenue.

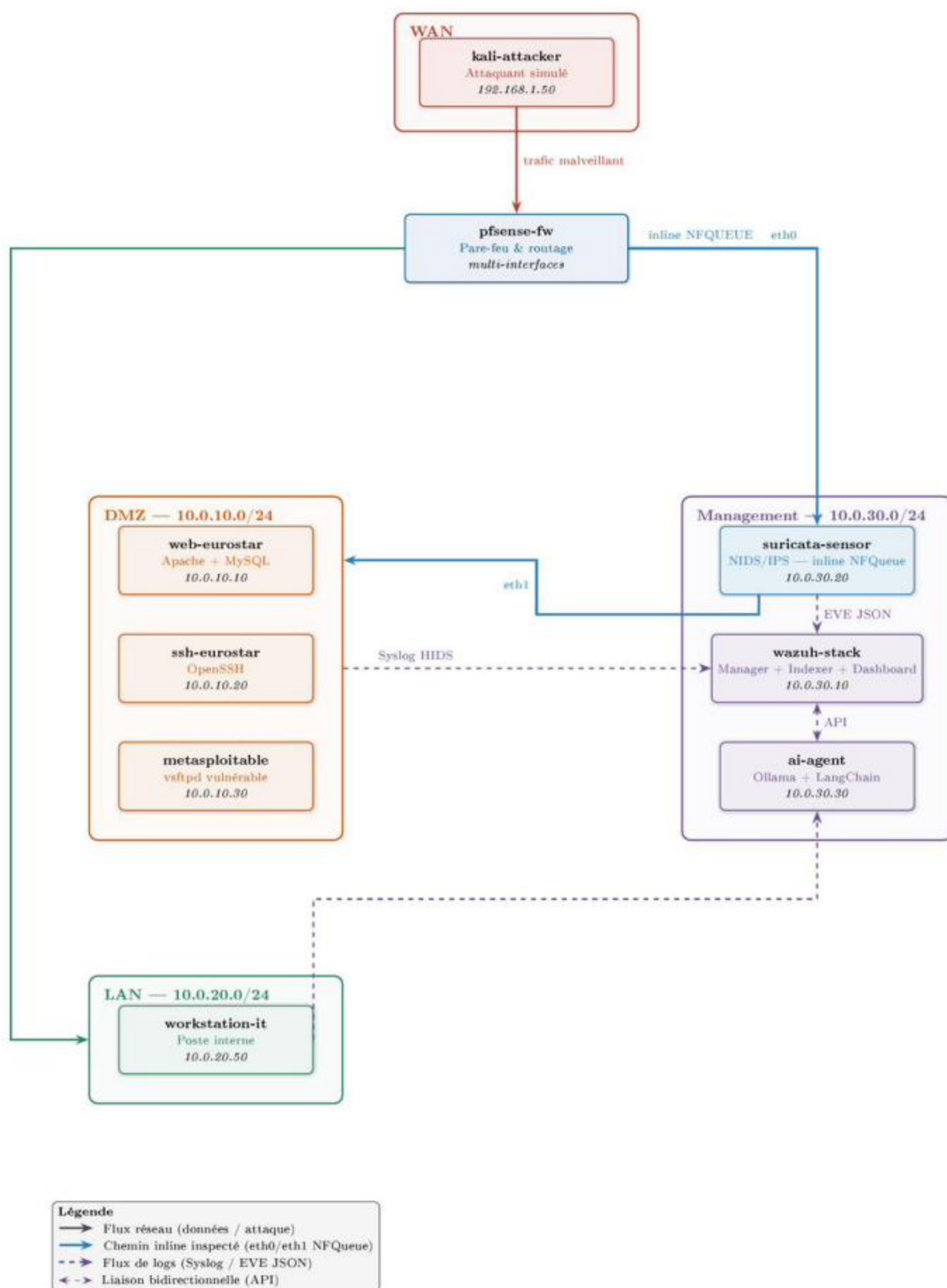


FIGURE 1 – Architecture réseau du laboratoire virtualisé. Le trafic entrant transite obligatoirement par le capteur Suricata en mode inline NFQueue (eth0/eth1) avant d’atteindre la DMZ. Les agents Wazuh HIDS et Suricata transmettent leurs événements au Wazuh Manager ; l’agent IA interroge ensuite le Manager via son API REST pour reconstruire la kill chain.

6.5. Politique de filtrage pfSense

Source	Dest.	Port(s)	Action	Justification
WAN	DMZ :10.10	80, 443	✓	Serveur web
WAN	DMZ :10.20	22	✓	Cible scénario B
WAN	DMZ :10.30	21	✓	Cible scénario D
WAN	LAN	Tout	×	LAN non exposé
WAN	MGMT	Tout	×	Management isolé
DMZ	LAN	Tout	×	Pas mouvement latéral
DMZ	MGMT	Syslog	✓	Remontée logs
LAN	MGMT	HTTPS	✓	Dashboard SOC

7. Scénarios d'attaque

7.1. Cadre méthodologique — MITRE ATT&CK

Le framework **MITRE ATT&CK** (Adversarial Tactics, Techniques and Common Knowledge) décompose les attaques en tactiques (l'objectif de l'attaquant) et techniques (la méthode employée). Il est intégré nativement dans Wazuh et sert de référentiel à l'agent IA pour nommer les étapes de la kill chain.

7.2. Sélection et définition des scénarios

Les quatre scénarios retenus ont été **définis conjointement avec le client** — Sophie Veron, Senior Information Security Expert chez Eurostar — sur la base des menaces représentatives auxquelles sont confrontées les grandes organisations dans le secteur des transports internationaux. Ce choix répond directement à l'exigence BF-02 du cahier des charges, qui fixe la priorité sur la qualité et la profondeur de couverture de chaque scénario plutôt que sur la multiplication de cas partiellement traités. Les types de menaces retenus — balayage réseau, force brute, injection SQL et exploitation de vulnérabilité — ont été validés par Sophie Veron comme représentatifs des risques réels auxquels Eurostar est confrontée.

La sélection a privilégié la **qualité et la profondeur de couverture** de chaque scénario plutôt que la multiplication de cas partiellement traités. Les scénarios sont ordonnés du **moins complexe au plus complexe**, cette progression étant alignée sur les trois itérations du projet : chaque scénario s'appuie sur les capacités de détection et de corrélation mises en place lors des itérations précédentes, permettant une montée en puissance progressive et démontrable.

#	Scénario	Cx.	Tactique MITRE	Outil	Itération
A	Reconnaissance réseau	★	Discovery	Nmap	MVP
B	Force brute SSH	★★	Credential Access	Hydra	It. 2
C	Injection SQL	★★	Initial Access	sqlmap	It. 2
D	Exploitation Metasploit	★★★	Initial Access / Persistence	Metasploit	It. 3

7.3. Scénario A — Reconnaissance réseau (Nmap)

Complexité : ★

Justification client : toute cyberattaque débute par une phase de reconnaissance. La détection précoce d'un balayage réseau permet d'anticiper une attaque avant qu'elle n'atteigne sa phase d'exploitation.

Kill chain : TA0043 Reconnaissance → T1595.001 Scanning IP Blocks ; TA0007 Discovery → T1046 Network Service Discovery.

```
1 nmap -sS -A -p 1-1000 192.168.1.0/24
```

Listing 3 – Commande Nmap — Scénario A

Détection : alerte Suricata SYN scan, Wazuh niveau 7, T1046, blocage IP après seuil.

Rôle IA : identifier la phase comme reconnaissance préalable et interroger l'historique Wazuh pour des activités antérieures de la même source.

7.4. Scénario B — Force brute SSH (Hydra)

Complexité : ★★

Justification client : les attaques par force brute sur SSH sont parmi les vecteurs d'accès initial les plus fréquents dans les environnements d'entreprise. Ce scénario introduit la notion de **corrélation** entre deux événements distincts (échecs d'authentification puis succès), étape clé vers la reconstruction de la kill chain.

Kill chain : TA0006 Credential Access → T1110.001 Password Guessing ; TA0001 Initial Access → T1078 Valid Accounts (après succès).

```
1 hydra -l admin -P /usr/share/wordlists/rockyou.txt -t 4 ssh
   ://192.168.1.10
```

Listing 4 – Commande Hydra — Scénario B

Détection : Suricata brute force SSH, HIDS auth.log, corrélation échecs→succès (alerte niveau 15), blocage IP automatique.

Rôle IA : kill chain 2 étapes (T1110 → T1078), recommandation de révocation des accès SSH.

7.5. Scénario C — Injection SQL (sqlmap)

Complexité : ★★

Justification client : Eurostar exploite des applications web exposant des données sensibles (gestion des réservations, données passagers). L'injection SQL cible directement la couche applicative, non détectable par un NIDS seul car le trafic HTTP est légitime en surface — ce scénario valide l'apport indispensable du **HIDS** (BF-01).

Kill chain : TA0001 Initial Access → T1190 Exploit Public-Facing Application ; TA0009 Collection → T1213 Data from Information Repositories.

```
1 sqlmap -u "http://192.168.1.10/login.php?id=1" --dbs --batch
```

Listing 5 – Commande sqlmap — Scénario C

Détection : patterns SQLi Suricata, HIDS apache access.log, identification User-Agent sqlmap, T1190.

Rôle IA : corréler les requêtes en campagne SQLi active, estimer la criticité selon les tables ciblées.

7.6. Scénario D — Exploitation Metasploit (vsftpd 2.3.4 [16]) Complexité : ***

Justification client : scénario le plus représentatif d’une attaque réelle avancée. Il couvre l’intégralité des phases d’une intrusion — exploitation, exécution, persistance — et constitue la **démonstration phare** de la capacité de corrélation multi-étapes de la solution et de la reconstruction automatique de la kill chain par l’agent IA.

Kill chain : TA0001 Initial Access → T1190 ; TA0002 Execution → T1059.004 Unix Shell ; TA0003 Persistence → T1136.001 Create Local Account + T1543.002 Systemd Service.

```
1 use exploit/unix/ftp/vsftpd_234_backdoor
2 set RHOSTS 192.168.1.10
3 exploit
4 # Post-exploitation : creation d'une backdoor persistante
5 echo "backdoor_usr:x:0:0:::/root:/bin/bash" >> /etc/passwd
```

Listing 6 – Session Metasploit — Scénario D

Détection : pattern vsftpd Suricata, création user root HIDS, service systemd suspect HIDS FIM, corrélation kill chain 3 étapes, alerte niveau 15.

Rôle IA : rapport SOC complet — kill chain reconstruite, score de risque 94/100, recommandations d’isolement et de remédiation en langage naturel.

7.7. Scénarios bonus — Si le temps le permet

Trois scénarios supplémentaires ont été identifiés avec le client et pourront être implémentés si les contraintes temporelles le permettent, en prolongement des itérations principales. Ils sont présentés par ordre de priorité :

#	Scénario	Cx.	Technique MITRE	Justification
E	Mouvement latéral (Pass-the-Hash)	***	T1550.002	Propagation interne après compromission initiale
F	Exfiltration DNS Tunneling (dnscat2)	***	T1048, T1071.004	Canal discret rarement filtré par les pare-feux
H	Ransomware simulé (Python)	***	T1486, T1490	Impact maximal, très représentatif des menaces actuelles

Ces scénarios bonus feront l’objet d’une mention dans les perspectives d’amélioration du rapport final, indépendamment de leur implémentation effective.

8. Stratégie de validation

8.1. Trois niveaux complémentaires

1. **Unitaire** : chaque composant fonctionne isolément.
2. **Intégration** : un log traverse la chaîne en $< 60s$.
3. **Fonctionnel** : les 4 scénarios sont détectés bout en bout avec critères d’acceptation mesurables.

8.2. Critères d’acceptation par fonctionnalité

Les critères suivants permettent de vérifier que chaque besoin fonctionnel exprimé dans le cahier des charges est effectivement satisfait par la solution déployée. Chaque critère est **mesurable et vérifiable** lors de la démonstration ou à partir des captures d’écran annotées du rapport.

BF	Critère d'acceptation	Indicateur mesurable	Méthode
BF-01	Les événements de tous les composants (NIDS, HIDS, système) sont visibles dans un tableau de bord unique.	Au moins 3 sources de logs distinctes présentes simultanément dans Wazuh Dashboard.	Dashboard
BF-02	Les 4 scénarios d'attaque représentatifs sont détectés.	Une alerte est générée pour chacun des scénarios A, B, C, D dans les 60 secondes.	eve.json
BF-03	Le trafic malveillant est bloqué sans intervention humaine.	Après scénario A, la source est injoignable en $\leq 30s$; vérifié par ping depuis Kali.	Test réseau
BF-04	Les alertes sont classées en niveaux différenciés.	Dashboard affiche ≥ 3 niveaux ; scénario D produit niveau ≥ 12 .	Dashboard
BF-05	La solution relie des événements en kill chain cohérente.	Scénario D : kill chain ordonnée couvrant ≥ 3 étapes MITRE distinctes.	Rapport IA
BF-06	Chaque alerte contient les informations minimales du CDC.	Règle, timestamp, IP src/dst, ports, protocole et sévérité présents sur 5 alertes tirées au sort.	eve.json
BF-07	Le dashboard SOC présente vue temps réel et vue historisée.	(1) Alertes 24 h classées par niveau ; (2) graphique de volume sur 4 semaines.	Dashboard
BF-08	Un mécanisme d'escalade automatique est opérationnel.	Ticket ou notification déclenché automatiquement lors d'une alerte de niveau ≥ 12 .	Logs Wazuh
BF-09	Les règles de détection sont administrables (CRUD + MAJ).	Ajout d'une règle custom, test, désactivation ; MAJ Emerging Threats [24] tracée dans Git.	Wazuh + Git
BF-10	L'architecture est documentée comme scalable multi-sites.	Justification théorique : ajout d'un site via Ansible sans refonte de l'architecture.	Rapport
BF-11	Le composant IA réduit les faux positifs et les faux négatifs et priorise les alertes.	Trafic mixte 60 min : taux FP post-filtrage $<$ taux brut ; cohérence priorisation $\geq 80\%$ vs sévérité manuelle.	Script Python

8.3. Critères d'acceptation par scénario

Sc.	ID	Critère d'acceptation	Méthode
A	A1	Alerte SYN scan en < 30s	eve.json
	A2	Alerte visible dans Wazuh Dashboard	Dashboard
	A3	Technique T1046 affichée	Alerte
	A4	IP bloquée après seuil	Test réseau
B	B1	Tentatives SSH détectées par HIDS	auth.log
	B2	Corrélation échec→succès	Alerte composite
	B3	Alerte niveau 15	Dashboard
	B4	Blocage IP automatique	Test réseau
C	C1	SQLi détectée NIDS+HIDS	eve.json+access.log
	C2	User-Agent sqlmap remonté	Alerte
	C3	T1190 mappé	Dashboard
D	D1	Exploitation vsftpd détectée	Suricata
	D2	Création user root	HIDS
	D3	Service systemd suspect	HIDS FIM
	D4	Kill chain 3 étapes	Alerte composite

8.4. Validation du composant IA

Capacité IA	Méthode	Critère
Réduction faux positifs	Alertes brutes vs filtrées (trafic mixte 1h)	Réduction mesurable
Détection faux négatifs	Attaque subtile vs règles statiques seules	Détection supplémentaire
Priorisation	Score IA vs sévérité manuelle	Cohérence $\geq 80\%$
Reconstruction kill chain	Comparaison avec vérité terrain	Étapes ordonnées
Rapport SOC	Évaluation qualitative	Actionnable

9. Analyse de sécurité et conformité RGPD

9.1. Dimension réflexive

La solution étant elle-même un dispositif de sécurité, elle constitue une cible privilégiée. Un SIEM compromis permettrait d'effacer les traces et d'aveugler la détection. L'analyse distingue les biens du SI surveillé de ceux de l'infrastructure de détection.

9.2. Biens à protéger

Asset	Niveau	C	I	D	Justification
Logs sécurité	Critique	✓	✓	✓	Falsification masque une attaque
Wazuh Manager	Critique	✓	✓	✓	Compromission aveugle la détection
Base OpenSearch	Critique	✓	✓	○	Historique 1 an (BNF-10)
Règles détection	Élevé	○	✓	✓	Modification silencieuse
Dashboard SOC	Élevé	✓	○	✓	Accès données sensibles
Agent IA + LLM	Moyen	○	✓	○	Empoisonnement analyses
Credentials admin	Critique	✓	✓	—	Accès complet

9.3. Matrice des risques

ID	Menace	Proba.	Impact	Risque
M-01	Falsification logs	Moy.	Critique	Élevé
M-02	Compromission Manager	Faible	Critique	Moyen
M-03	Accès non autorisé dashboard	Moy.	Élevé	Moyen
M-04	Injection faux événements	Moy.	Élevé	Moyen
M-05	Désactivation règles	Faible	Critique	Moyen
M-08	Empoisonnement modèle IA	Faible	Moyen	Faible
M-09	Vol credentials	Moy.	Critique	Élevé

9.4. Contre-mesures

Intégrité des logs (M-01, M-04) : TLS natif Wazuh agent-manager, zone MGMT isolée pfSense, horodatage et signature des événements.

Accès non autorisés (M-03, M-09) : RBAC sur le dashboard Wazuh, accès limité aux zones LAN/MGMT, journalisation (BNF-09).

Intégrité des règles (M-05) : versionnement GitHub (BF-09), surveillance FIM sur les répertoires de configuration de l'IDS/IPS et du SIEM.

9.5. Risques résiduels

- Attaques zero-day : l'IA réduit ce risque sans l'éliminer.
- Compte admin légitime compromis : aucune mesure technique ne protège contre un identifiant valide.
- Limites lab : ne valide pas le passage à l'échelle.
- Faux négatifs IA : les règles statiques sont conservées en parallèle.

9.6. Conformité RGPD

Le projet adopte une approche *privacy by design* : aucune donnée à caractère personnel n'est traitée en laboratoire.

Point juridique — Arrêt Breyer (CJUE, C-582/14, 2016) [2]

Les adresses IP dynamiques constituent des données à caractère personnel. Dans un déploiement réel, le SIEM exigerait une base légale de traitement, une durée de conservation proportionnée et l'information des personnes concernées.

10. Planning de réalisation

10.1. Contraintes temporelles

Dépôt rapport : **17 août 2026**. Défense : **septembre 2026**. Travail en autonomie complète. Maximum de disponibilité en juin ; contraintes début juillet et du 25 juillet au 2 août.

10.2. Planning détaillé

Phase	Période	Sprint	Objectif	Livrable
0 — Analyse	28/05–07/06	S0	Mise en forme LaTeX, soumission	Document analyse
1 — Lab	08/06–14/06	S1	GNS3, pfSense, Wazuh Docker	Réseau fonctionnel
1 — Lab	15/06–21/06	S2	Suricata inline, agents HIDS	Chaîne complète
2 — MVP	22/06–28/06	S3	Scénario A + Isolation Forest	MVP validé
3 — It.2	29/06–05/07	S4	Scénario B (SSH)	Tests documentés
3 — It.2	06/07–12/07	S5*	Scénario C (SQLi)	Tests documentés
4 — It.3	13/07–19/07	S6	Scénario D (Metasploit)	Solution complète
4 — It.3	20/07–24/07	S7	Agent LangChain + vidéo démo	Démo enregistrée
Pause	25/07–02/08	—	—	—
5 — Rédac.	03/08–09/08	S8	Chapitres pratiques, captures	Chapitres rédigés
5 — Rédac.	10/08–17/08	S9	Conclusions, bibliographie	Dépôt 17/08

* Disponibilité réduite ($\approx 3\text{h/jour}$)

10.3. Jalons go/no-go et itérations

Trois jalons structurent l’avancement : J1 (21 juin) — laboratoire fonctionnel (Suricata → Wazuh → Dashboard); J2 (28 juin) — MVP validé (scénario A + Isolation Forest); J3 (24 juillet) — 4 scénarios validés et vidéo démo enregistrée.

Itération	Fonctionnalités	Composant IA
MVP	Lab, scénario A, dashboard minimal	Isolation Forest
Itération 2	Scénarios B et C, HIDS	Priorisation alertes
Itération 3	Scénario D, dashboard SOC, RÌ	Kill chain complète

11. Conclusion

Ce document a présenté l’analyse complète du projet, couvrant le contexte et la problématique, les besoins fonctionnels (BF-01 à BF-11) et non fonctionnels (BNF-01 à BNF-10), les fondements théoriques, les choix technologiques justifiés, la conception du laboratoire, les quatre scénarios d’attaque, la stratégie de validation, l’analyse de sécurité et le planning. Les choix technologiques forment une stack cohérente et entièrement gratuite, compatible avec les contraintes matérielles et les exigences de reproductibilité et de déployabilité de la solution.

La plus-value distinctive de ce TFE réside dans l’intégration d’un agent LangChain s’appuyant sur Llama 3.1 8B via Ollama pour reconstruire automatiquement les chaînes d’attaque en langage naturel, réduire les faux positifs et les faux négatifs (Isolation Forest) et produire des rapports d’incident exploitables par une équipe SOC — allant au-delà d’un déploiement IDS/IPS et SIEM conventionnel.

Bibliographie

- [1] CISCO TALOS, *Snort 3 User Manual*, 2024. adresse : <https://www.snort.org/documents>.
- [2] COUR DE JUSTICE DE L'UNION EUROPÉENNE, *Arrêt Breyer c. Bundesrepublik Deutschland, Qualification des adresses IP dynamiques comme données à caractère personnel*, 2016. adresse : <https://curia.europa.eu/juris/document/document.jsf?docid=184668>.
- [3] DOCKER INC., *Docker Documentation*, 2024. adresse : <https://docs.docker.com/>.
- [4] ELASTIC N.V., *Elastic Security Documentation*, 2024. adresse : <https://www.elastic.co/guide/en/security/current/index.html>.
- [5] EUROPEAN UNION AGENCY FOR CYBERSECURITY (ENISA), “ENISA Threat Landscape 2024,” ENISA, 2024, Rapport annuel sur les menaces cybernétiques en Europe. adresse : <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2024>.
- [6] P. GARCIA-TEODORO, J. DIAZ-VERDEJO, G. MACIA-FERNANDEZ et al., “Anomaly-based network intrusion detection : Techniques, systems and challenges,” *Computers & Security*, t. 28, n° 1–2, p. 18–28, 2009.
- [7] GNS3 TECHNOLOGIES INC., *GNS3 Documentation*, 2024. adresse : <https://docs.gns3.com/>.
- [8] van HAUSER et THC, *THC-Hydra – Fast and flexible online password cracking tool*, 2024. adresse : <https://github.com/vanhauser-thc/thc-hydra>.
- [9] E. M. HUTCHINS, M. J. CLOPPERT et R. M. AMIN, “Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains,” *Proceedings of the 6th International Conference on Information Warfare and Security*, p. 113–125, 2011, Lockheed Martin Corporation – article fondateur du modèle Cyber Kill Chain.
- [10] IBM, *IBM QRadar SIEM Documentation*, 2024. adresse : <https://www.ibm.com/docs/en/qsip>.
- [11] LANGCHAIN INC., *LangChain Documentation*, 2024. adresse : https://python.langchain.com/docs/get_started/introduction.
- [12] LINUX AUDIT PROJECT, *Auditd – Linux Audit Daemon*, 2024. adresse : <https://man7.org/linux/man-pages/man8/auditd.8.html>.
- [13] G. LYON, *Nmap Network Scanning : The Official Nmap Project Guide to Network Discovery and Security Scanning*, 2009. adresse : <https://nmap.org/book/>.
- [14] META AI, *Llama 3 : Open Foundation and Fine-Tuned Chat Models*, 2024. adresse : <https://ai.meta.com/blog/meta-llama-3/>.
- [15] MITRE CORPORATION, *MITRE ATT&CK® Enterprise Matrix*, 2024. adresse : <https://attack.mitre.org/>.
- [16] NATIONAL VULNERABILITY DATABASE, *CVE-2011-2523 – vsftpd 2.3.4 Backdoor*, 2011. adresse : <https://nvd.nist.gov/vuln/detail/CVE-2011-2523>.

- [17] NETFILTER PROJECT, *libnetfilter_queue – Netfilter Queue Library*, 2024. adresse : https://netfilter.org/projects/libnetfilter_queue/.
- [18] NETGATE, *pfSense Documentation*, 2024. adresse : <https://docs.netgate.com/pfsense/en/latest/>.
- [19] OISF – OPEN INFORMATION SECURITY FOUNDATION, *Suricata Documentation*, 2024. adresse : <https://docs.suricata.io/en/latest/>.
- [20] OISF – OPEN INFORMATION SECURITY FOUNDATION, *Suricata IPS Mode via Netfilter (NFQueue)*, 2024. adresse : <https://docs.suricata.io/en/latest/setting-up-ipsinline-for-linux.html>.
- [21] OLLAMA, *Ollama Documentation*, 2024. adresse : <https://ollama.ai/>.
- [22] OSSEC PROJECT, *OSSEC Documentation*, 2023. adresse : <https://www.ossec.net/docs/>.
- [23] PARLEMENT EUROPÉEN ET CONSEIL DE L'UNION EUROPÉENNE, *Règlement (UE) 2016/679 relatif à la protection des personnes physiques à l'égard du traitement des données à caractère personnel (RGPD)*, 2016. adresse : <https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32016R0679>.
- [24] PROOFPOINT – EMERGING THREATS, *Emerging Threats Open Ruleset*, 2025. adresse : <https://rules.emergingthreats.net/>.
- [25] RAPID7, *Metasploit Framework Documentation*, 2024. adresse : <https://docs.metasploit.com/>.
- [26] SPLUNK INC., *Splunk Enterprise Security Documentation*, 2024. adresse : <https://docs.splunk.com/Documentation/ES>.
- [27] SQLMAP DEVELOPMENT TEAM, *sqlmap – Automatic SQL Injection and Database Takeover Tool*, 2024. adresse : <https://sqlmap.org/>.
- [28] WAZUH INC., *Wazuh Docker Deployment*, 2024. adresse : <https://documentation.wazuh.com/current/deployment-options/docker/index.html>.
- [29] WAZUH INC., *Wazuh Documentation*, 2024. adresse : <https://documentation.wazuh.com/current/index.html>.
- [30] ZEEK PROJECT, *Zeek Documentation*, 2024. adresse : <https://docs.zeek.org/en/master/>.